

1. Incident Overview

This use case focuses on detecting attempts to compromise user accounts through brute-force activity, geolocation anomalies, and suspicious password resets. These behaviors can lead to unauthorized access, credential abuse, privilege escalation, and lateral movement.

2. Incident Analysis

2.1 Indicators of Compromise (IoCs)

The following alerts are considered **key indicators of account compromise attempts**:

Rule 1 — Multiple Login Failures

- Excessive failed login attempts from a single IP or username
- Possible brute-force or password spraying
- Often a precursor to successful password guessing

Rule 2 — Login From Unusual Country

- Successful login from a region not associated with the user
- Sudden geolocation change (possible VPN/proxy use)
- May indicate compromised credentials successfully used by an attacker

Rule 3 — Unusual Password Reset Activity

- Password changed/reset multiple times within a short window
 - Possible attacker trying to lock user out
 - Defender attempt to maintain persistence by controlling the credentials
-

2.2 Root Cause Analysis Questions

During analysis, the SOC must answer:

Credential Exposure

- Were credentials leaked (phishing, malware, reuse)?
- Was the user targeted by known phishing activity?

System Behavior

- Did successful login occur after failed attempts?
- Was there a suspicious IP, TOR node, VPN service?
- Is there evidence of automated login scripts or bots?

User Verification

- Did the user confirm the activity as legitimate?
- Is the user currently locked out of their account?

Additional Follow-Up

- Did the attacker access sensitive systems after login?
 - Was MFA bypassed or temporarily disabled?
-

3. Incident Containment

Containment focuses on preventing further unauthorized access while protecting the user and systems.

3.1 Immediate Containment Actions

For Multiple Login Failures

- Block the offending IP or network ranges
- Increase the lockout thresholds (if configurable)
- Enforce MFA for the impacted user

For Login From Unusual Country

- Force logoff sessions associated with suspicious login
- Block the unusual country (if policy allows)
- Reset session tokens and revoke access keys

For Unusual Password Reset Activity

- Disable the affected account temporarily

- Invalidate password reset tokens
- Verify identity with the user before re-enabling

3.2 SOC Escalation Matrix

Alert Type	Escalate To	When
Multiple Login Failures	L2 Analyst	Persistent attempts > threshold
Unusual Country Login	L3 Analyst / IR Team	Confirmed unauthorized login
Password Reset Abuse	IAM / Security Admin	Multiple resets in 10–15 min

4. Eradication

Eradication involves removing the threat actor's presence and ensuring no further compromise can occur.

Actions:

- Reset user password with strong complexity
 - Force MFA enrollment or re-enrollment
 - Revoke all sessions, OAuth tokens, API keys
 - Remove malicious IPs from allow lists
 - Update endpoint with latest patches (if relevant)
 - Review logs for post-login malicious activity
 - Remove unauthorized forwarding rules (email compromise scenario)
-

5. Recovery

Steps:

- Re-enable the user's account after verification
- Restore access only after:
 - Password reset
 - MFA validated
 - No further suspicious login attempts
- Notify user about cause & preventive measures
- Monitor the affected account for 72 hours

6. Lessons Learned & Post-Incident Activities

After containment and eradication, the SOC performs a structured review.

6.1 Documentation

- Record timeline of attack
- Document source IPs, geolocations, event logs
- Keep evidence for possible legal use

6.2 Improvements

- Adjust thresholds (login failures, password resets)
- Strengthen geolocation access policies
- Enforce MFA universally
- Improve phishing awareness for users
- Harden account lockout policies

6.3 Cross-Team Communication

- Notify IAM and HR if user behavior is involved
- Share IoCs with threat intel team
- Inform IT for network-level blocking if required